

The New Responsibility of Open Source Program Offices: Risk Forecasting

Photo by Rahul Mishra on Unsplash

The New Responsibility of Open Source Program Offices: Risk Forecasting

Created on 2025-10-25 14:28

Published on 2025-11-04 16:35

Navigating Security, Sustainability, and Geopolitics in a Fractured World

Abstract

Over the past year, I've spoken with Open Source Program Office (OSPO) leaders across China, Europe, and North America, and one thing has become clear: the role of the OSPO is evolving. What began as a compliance and advocacy function is now being thrust into a far more complex position: forecasting and mitigating risk. The pace of technological change, regulatory scrutiny, and geopolitical tension is accelerating, and OSPOs are uniquely positioned to help organizations anticipate and navigate around corners. In this article, I'll share what I've learned from these conversations and outline how OSPO leaders everywhere can step up to meet the challenge.

Disclaimer

The views expressed in this document are solely my own and do not represent those of my current or past employers.

OSPO as Risk Forecaster

The traditional mission of an OSPO, promoting open source adoption, ensuring compliance, guiding contributions, and fostering community, remains critical. However, those responsibilities are no longer sufficient.

OSPOs must now evolve into risk forecasters, helping their organizations anticipate and respond to threats before they materialize.

This emerging OSPO role involves a shift in mindset: from reactive to proactive, from operational to strategic. The most forward-thinking OSPOs I've worked with are already embracing this expanded mandate and acting on it by:

- Identifying signals across ecosystems, monitoring vulnerabilities, tracking licensing changes, analyzing contributor dynamics, and assessing regulatory shifts.
- Connecting internal functions, bridging engineering, legal, product, and security to create a holistic view of risk across the organization.
- Advising leadership on long-term risks, from supply chain fragility to compliance gaps, and offering mitigation strategies.
- Building early-warning systems, tracking critical projects, and alerting leadership before a crisis erupts, and
- Aligning risk with business decisions, weighing open source risks against business priorities.

This ability to aggregate and interpret weak signals makes OSPOs indispensable at the executive table. However, to deliver on this promise, OSPOs must understand and address the three core risk areas reshaping open collaboration: (1) software security, (2) sustainability, and (3) geopolitical tensions. In the following section, we will explore these core risk areas and discuss how OSPOs can support their organizations in these specific areas.

Three Core Risk Areas

Risk in open source is multifaceted. To forecast effectively, OSPOs must focus on three interlinked domains: security, sustainability, and geopolitical tension. Each domain requires distinct strategies and contributes to the broader picture of organizational resilience. We'll start with security, arguably the most immediate and visible risk, before moving into the less obvious but equally critical areas of sustainability and geopolitics.

Risk Area 1: Software Security

Every conversation I have with OSPO leaders eventually turns to security. Vulnerabilities like Log4Shell and supply chain attacks, such as the SolarWinds breach, have made it clear that organizations are only as secure as their weakest dependency, often buried deep in a transitive chain. This is where OSPOs have stepped up as frontline advisors by:

- Monitoring the ecosystem for vulnerabilities and dependency risks.
- Interfacing with security teams, bringing specialized expertise in open source.

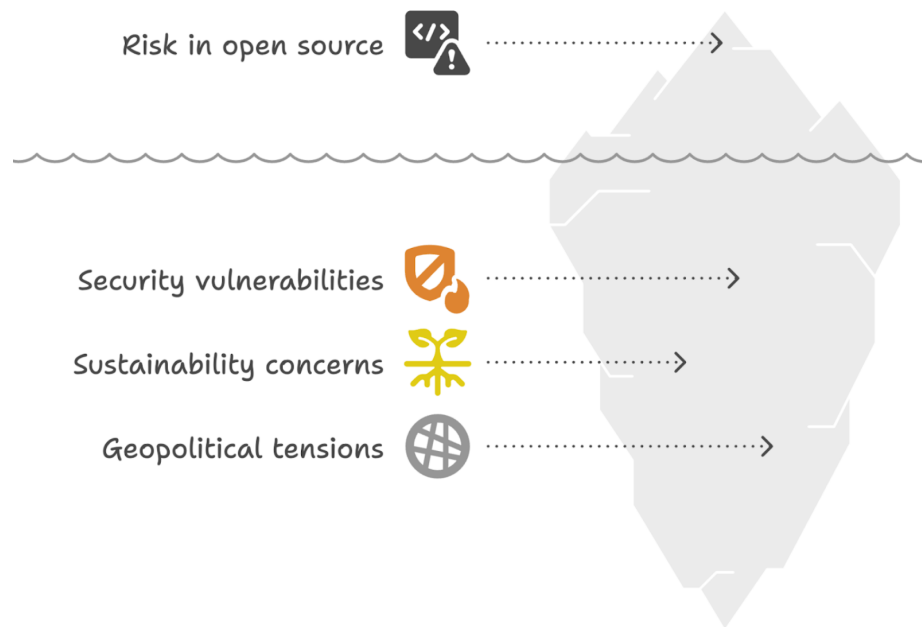


Figure 1: Open source risk: Unveiling the hidden depths

- Advocating for secure-by-default practices, such as SBOM generation and signed releases.
- Educating leadership that most vulnerabilities originate not from direct dependencies, but from transitive ones, often several layers deep.

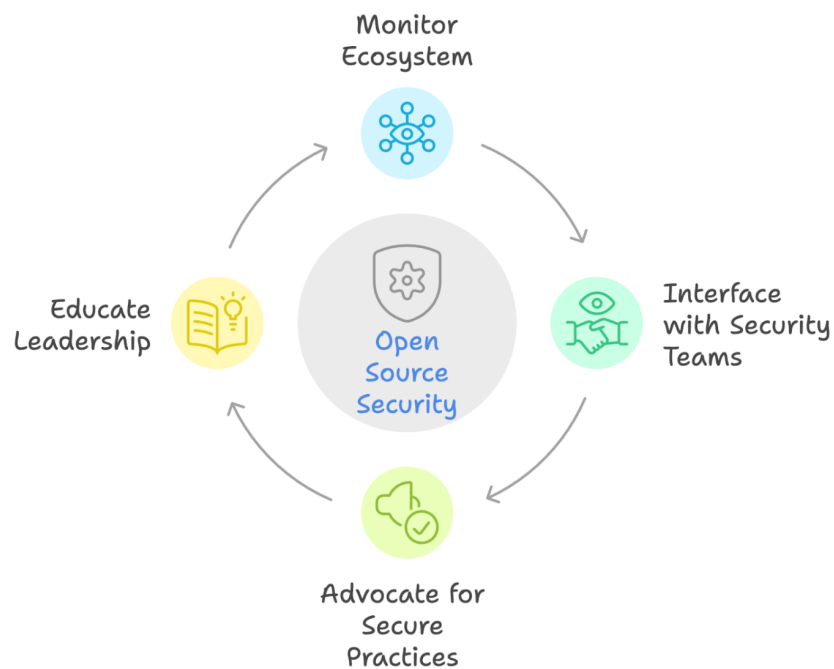


Figure 2:

In China, OSPOs are proactively mirroring upstream projects internally to guarantee trust and control, a practice that's gaining interest globally. By focusing on security, OSPOs can help organizations protect themselves against increasingly sophisticated threats. But even if you secure your dependencies, there's another looming risk: what happens if the projects you rely on simply ... stop?

Risk Area 2: Sustainability

Once you begin examining the sustainability of critical open source projects, it becomes difficult to stop. Many organizations assume that the software they depend on will “just be there,” but in reality, a handful of volunteers maintain many of these projects. This situation is especially acute in China, where companies rely heavily on Western-maintained projects, raising concerns about both business resilience and national security. OSPOs must:

- Audit critical dependencies for maintenance and funding gaps.
- Fund and contribute to key projects directly or through foundations.
- Identify projects with dangerously low contributor-to-user ratios and support or replicate them internally to ensure their sustainability.

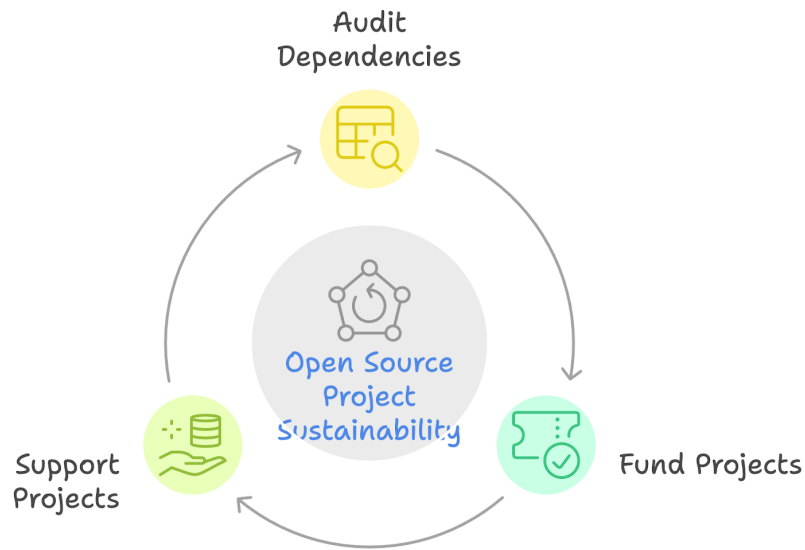


Figure 3:

Understanding and addressing sustainability helps mitigate the risk of critical components disappearing, and leads naturally into the geopolitical pressures reshaping the open source landscape.

Risk Area 3: Geopolitical Tensions

The third risk area, geopolitics, is the most sensitive and the least openly discussed. Open source thrives on openness, but national borders and interests are reasserting themselves. In China, the Xinchuang initiative (, “IT Application Innovation”) explicitly aims to reduce dependency on foreign technology by promoting domestic alternatives. This effort creates two contradictory pressures: encouragement to grow domestic open source capacity, and constraints on contributing to certain foreign projects.

Chinese OSPOs also contend with the Personal Information Protection Law (PIPL) and the Data Security Law (DSL), which impose strict rules on data localization, obtaining consent for data processing, and cross-border data transfers. These laws have forced some teams to fork or redevelop projects to comply with local regulations.

Globally, OSPOs must also navigate shifting rules:

- The U.S. Export Administration Regulations (EAR) now constrain contributions to some cryptographic and AI projects.
- The EU’s Cyber Resilience Act (CRA) threatens to impose accountability and certification requirements on the quality and security of open source software and its supply chain.

To manage these tensions, OSPOs must maintain tight alignment with legal teams, monitor foundation affiliations and export controls, and ensure trust and visibility within their ecosystems. OSPOs aim to contribute globally, but must also comply with national policies through a delicate balance.

Recommendations for OSPO Leaders

The world OSPOs operate in has shifted, and it demands action. Now, more than ever, beyond simply monitoring risks, OSPO leaders must actively design strategies that insulate their organizations from foreseeable disruptions, strengthen trust with stakeholders, and reinforce the open source ecosystems they depend on. Here’s a high-level blueprint on how to start:

1. Embed risk forecasting as part of your OSPO operation

- Build dashboards that aggregate signals from engineering, legal, and security teams.
- Present insights in business language that executives can act on.
- Establish early-warning systems for critical projects and maintainers.

2. Strengthen cross-functional ties and collaboration

- Be the glue that connects engineering, legal, product, and security.

- Ensure that open source decisions are made with a thorough understanding of the risks and consequences.

3. Advise executives

- Regularly brief leadership on strategic risks: security, sustainability, and geopolitical.
- Offer actionable recommendations backed by data.

4. Act decisively in the three core areas of security, sustainability, and geopolitics

- For security, champion proactive vulnerability management, SBOM generation and management, and secure-by-default practices.
- For sustainability, invest in and support the critical projects you rely on, directly or through foundations.
- For geopolitics, monitor regulatory changes, maintain diverse affiliations, and adapt strategies accordingly.

Additional Steps for Navigating Geopolitical and Regulatory Complexity

In light of increasing tensions and regulatory divergence, especially relevant to Chinese OSPOs but applicable globally, leaders should also consider the following actions.

1. Assess Exposure and Dependencies

- Conduct an internal audit to identify which open source components, tooling, and infrastructure your organization relies on that are maintained or hosted by US-based organizations. Understand the operational and strategic impact of potential restrictions or disruptions to those assets.
- Track and interpret global and local regulations that could affect open source participation and supply chain resilience. This includes monitoring the US Entity List, Export Administration Regulations (EAR), and sanctions regimes, which may restrict contributions to or use of certain projects.
- Understand local compliance obligations under China's Personal Information Protection Law (PIPL), Data Security Law (DSL), and Cybersecurity Law (CSL), particularly concerning cross-border data flows, personal data processing, and critical infrastructure data.
- Coordinate closely with your legal and compliance teams to assess the legal and reputational risks associated with contributing to, depending on, or



Figure 4:

hosting foreign open source projects. This multidimensional awareness enables organizations to avoid unexpected disruptions while maintaining their ability to engage meaningfully in open ecosystems.

2. Build Redundancy

Building technical and operational redundancies is critical. By reducing dependency on any single external provider or jurisdiction, organizations can maintain continuity and resilience even amid disruptions.

- Invest in self-hosted alternatives for critical services, including Git hosting (e.g., Gitee or internal GitLab instances), CI/CD pipelines, and package repositories. This setup ensures your engineering teams can continue to work and release software even if access to external platforms is interrupted.
- Establish and maintain mirrors of critical upstream repositories. For example, mirroring essential GitHub projects within your domestic infrastructure to protect against outages, access restrictions, or project deletion.
- Consider adopting multi-cloud strategies or leveraging domestic cloud providers, which can minimize reliance on global hyperscalers that may become subject to geopolitical or regulatory restrictions.

These steps not only enhance operational autonomy but also demonstrate prudent risk management to internal and external stakeholders.

3. Engage with Domestic Ecosystems

- Proactively engaging with domestic open source ecosystems. Participating in local and regional initiatives, including China's Xinchuang program and other state-endorsed efforts, can strengthen your organization's resilience while aligning with national digital strategies.
- Support developers in leading and maintaining critical open source projects, ensuring that domestic stakeholders have meaningful influence and a seat at the table when shaping technical and governance decisions. This helps reduce dependency on foreign-led projects where priorities may diverge from local needs.
- Monitor the governance evolution of major international foundations to understand how shifting political climates might impact your participation, obligations, or perceived neutrality. Establish relationships with neutral or regionally-friendly foundations, where contributions are less politically sensitive and participation aligns better with regional priorities.
- Look for opportunities to grow your organization's visibility and influence both within Chinese-led and international community-driven foundations, striking a balance that maintains access to global collaboration while safeguarding against potential geopolitical friction.

4. Clarify Legal Boundaries

- Work closely with your legal teams to understand both US Export Administration Regulations (EAR) and China's Personal Information Protection Law (PIPL) and Data Security Law (DSL).
- Ensure compliance with both sets of rules when contributing to or consuming open source software.

5. Diversify Foundation Participation

Overreliance on a handful of global, often US-based, open source foundations introduces risks, both operational and reputational. While it remains essential to engage with these international institutions due to their reach and expertise, OSPOs must proactively diversify their foundation relationships to include domestic players as well.

Actively contribute to and collaborate with domestic open source ecosystems as stewards. This involves investing in local foundations and emerging regional initiatives, and sponsoring open source alternatives for critical infrastructure that align with strategic autonomy goals.

By nurturing these alternatives and supporting local maintainers, you help reduce exposure to geopolitical shocks while strengthening the ecosystems your organization depends on.

Diversifying foundation participation not only mitigates risk but also positions your organization as a trusted and committed partner in the communities shaping the future of open technology.

6. Scenario Planning

To stay ahead of rapidly changing geopolitical, legal, and operational risks, OSPOs must adopt a structured scenario planning approach. This means going beyond reactive policies and actively mapping out *what-if scenarios* that could disrupt your open source strategy.

- Develop and document scenarios such as restricted access to global development platforms, revoked contribution rights to critical projects, or interruptions in upstream releases. Use these scenarios to identify vulnerabilities in your product roadmap, compliance posture, and certification processes.
- Build mirrors or alternative access strategies for key dependencies and development infrastructure to ensure continuity and redundancy.
- Collaborate closely with product, legal, and security teams to assess how these scenarios would impact deliverables and timelines, and incorporate mitigation strategies into planning cycles.

By embedding scenario planning into your OSPO’s risk management practices, you equip leadership with actionable foresight, enabling smarter, faster decisions when disruptions inevitably arise.

7. Prepare Communication Strategies

If your organization maintains a high profile in US-based projects, develop clear public communication strategies about your intent and practices. Transparency fosters trust with contributors, regulators, and partners and mitigates unnecessary suspicion.

- Contribute to depoliticizing open source narratives where possible.
- Emphasize technical meritocracy, openness, and collaboration in all public engagements.
- Build alliances with neutral international partners who share the view that open source should remain borderless and apolitical.

8. Executive Reporting

For OSPOs to truly function as strategic advisors, they must bridge the gap between technical detail and executive decision-making. This requires a deliberate approach to executive reporting.

Develop and deliver regular internal briefings that summarize key geopolitical, regulatory, and ecosystem developments, highlighting their potential impact on your organization’s open source operations. Go beyond raw data, translate technical risks and signals into strategic language that resonates with senior stakeholders.

These reports should not only explain what’s happening but also recommend proactive measures, such as code repatriation, maintaining local forks of critical projects, or investing in domestic developer talent pipelines. By keeping the executive team informed and aligned, OSPOs ensure that open source risk management remains integrated into broader corporate strategy.

9. Prioritize Strategic Autonomy

Ultimately, your goal is to preserve your organization’s ability to contribute to and benefit from open source while maintaining operational independence. OSPOs play a central role in managing this delicate balance, enabling participation without undue exposure.

Final Thoughts

Open source has always depended on trust between individuals, organizations, and across borders. Security breaches, under-resourced projects, and rising

geopolitical tensions are now testing that trust. OSPOs have become the strategic nerve centers for managing this complexity. The next few years will test the resilience of the open collaboration model. Security risks will rise. Critical projects may lack needed support. Geopolitical and regulatory pressures will intensify. However, these challenges also present an opportunity for OSPOs to lead, helping their organizations anticipate and act before problems escalate, and preserve the open, collaborative spirit that made software innovation possible.

If you're leading an OSPO today, don't wait to be asked. Start forecasting, start preparing, and start owning the future.

About the Author

Dr Ibrahim Haddad is currently Head of Infotainment at Volvo Cars. He is widely recognised for his leadership in building and scaling Open Source Program Offices (OSPOs), having founded and directed them across multiple organisations, and advised both corporations and NGOs on open source strategy and governance. Previously, he served as Vice President of Strategic Programs (AI) at the Linux Foundation, where he was the Executive Director of LF AI & Data and the Founding Executive Director of the PyTorch Foundation. During his last tenure at the Linux Foundation, his core mandate was to support and grow the open source AI ecosystem by providing a neutral, trusted hub for developers and organizations to code, manage, and scale open source AI projects. Before the Linux Foundation, Dr Haddad served as Vice President of R&D and Distinguished Engineer at Samsung Research Silicon Valley. His career includes R&D technical and leadership roles at Ericsson Research, Open Source Development Labs, Motorola, Palm, and Hewlett-Packard. He holds a PhD with honours in Computer Science from Concordia University (Montréal, Canada).

[LinkedIn](#) - [Website](#)